



ICT306 Advanced Cybersecurity

WEEK 3(A) Network Scanning

Exploring the techniques, tools, and methodologies used by ethical hackers and security professionals to map networks, discover live hosts, identify open ports, and assess vulnerabilities.

PRESCRIBED READING

Resources

Core Textbook

Meredith, D. (2022). *Certified Ethical Hacker (CEH) v12 312-50 Exam Guide: Keep up to date with ethical hacking trends and hone your skills with hands-on activities.* Packt Publishing Ltd.

Focus on **Module 03** — Network Scanning. This module covers the full CEH scanning methodology, tools, and techniques you are expected to master for both the exam and practical application.

What to Focus On

- CEH scanning methodology steps
- TCP/IP flag behavior and handshakes
- Nmap and Hping3 command syntax
- IDS evasion and countermeasures
- Vulnerability and banner grabbing concepts

How Tech Companies Prepare for Cyber Attacks



Organizations are rapidly increasing their cybersecurity investments in response to growing threats. **98%** of small and mid-size companies are devoting more resources to cyber security, with **78%** reporting their data and intellectual property are at risk.

The most common investment areas include **Monitoring/Assessment (18%)**, **Policies/Controls (15%)**, and Hiring (12%). Notably, **54%** of non-security companies now plan to add a cybersecurity component to their product.

Module Objectives

Core Skills

- Overview of Network Scanning
- Techniques to check for Live Systems
- Techniques to check for Open Ports
- Understanding various Scanning Techniques
- Understanding IDS Evasion Techniques

Advanced Topics

- Understanding Banner Grabbing
- Overview of Vulnerability Scanning
- Drawing Network Diagrams
- Using Proxies and Anonymizers for Attack
- IP Spoofing and Detection Techniques
- Overview of Scanning Pen Testing

Overview of Network Scanning

Network scanning refers to a set of procedures used to identify hosts, ports, and services within a network. It is a critical component of intelligence gathering during the reconnaissance phase of an ethical hack — enabling an attacker or tester to build a comprehensive profile of the target organization.

Discover Live Hosts

Identify active IP addresses and open ports on the network.

Identify OS & Architecture

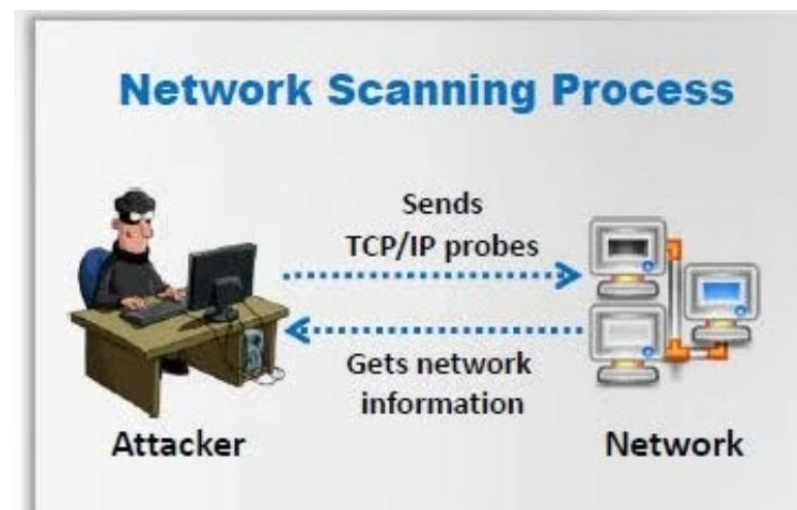
Determine operating systems and system architecture in use.

Enumerate Services

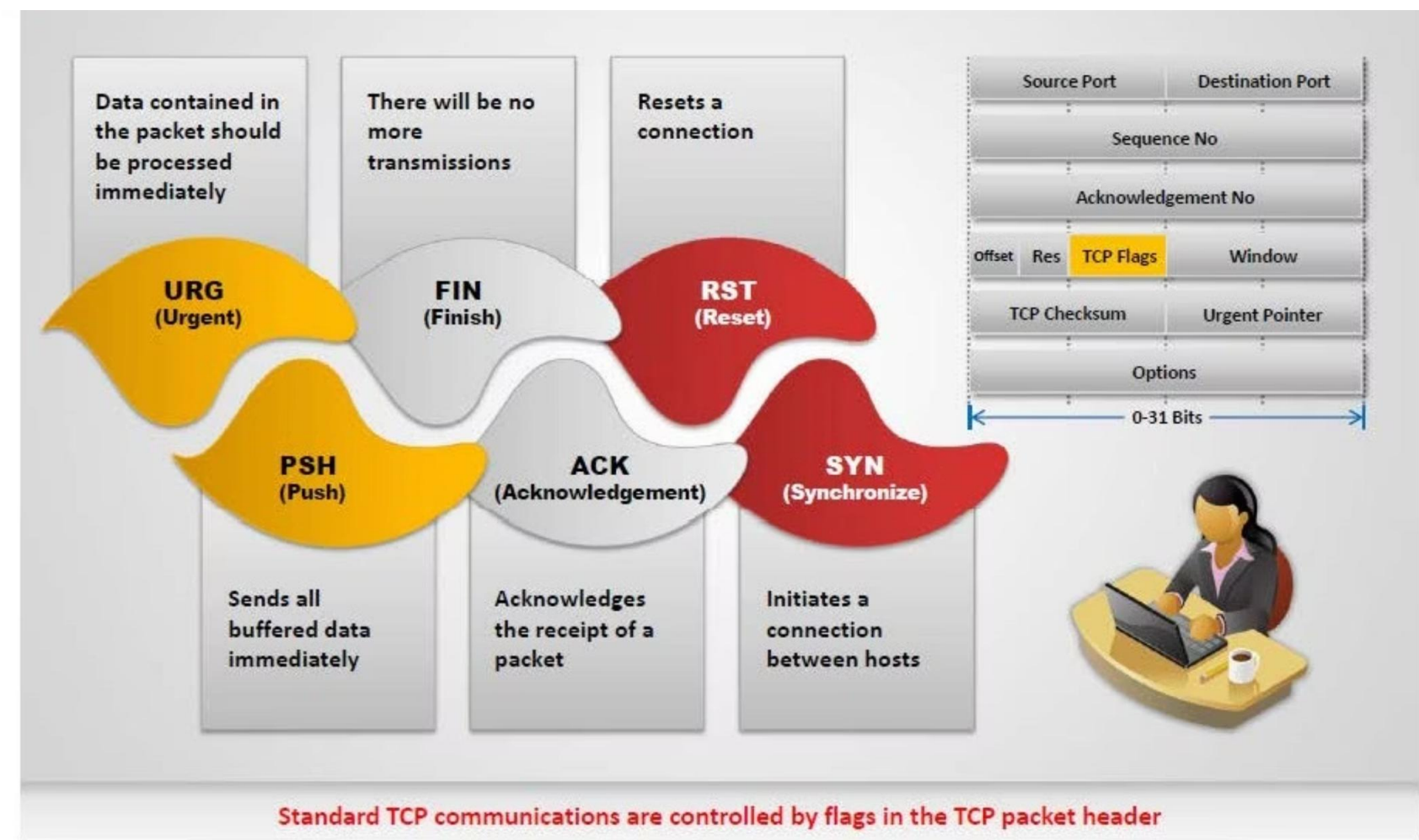
Discover services and applications running on live hosts.

Find Vulnerabilities

Detect weaknesses that could be exploited in live hosts.



TCP Communication Flags



Standard TCP communications are controlled by **flags embedded in the TCP packet header**. These flags govern how connections are established, maintained, and terminated. Understanding them is essential for crafting or interpreting network scan packets.

URG (Urgent) Data in the packet should be processed immediately.	PSH (Push) Sends all buffered data to the receiver immediately.	FIN (Finish) Signals no more data will be transmitted from sender.	ACK (Acknowledgement) Acknowledges receipt of a packet from the sender.
RST (Reset) Abruptly resets and terminates a connection.		SYN (Synchronize) Initiates a new connection between two hosts.	

TCP/IP Communication

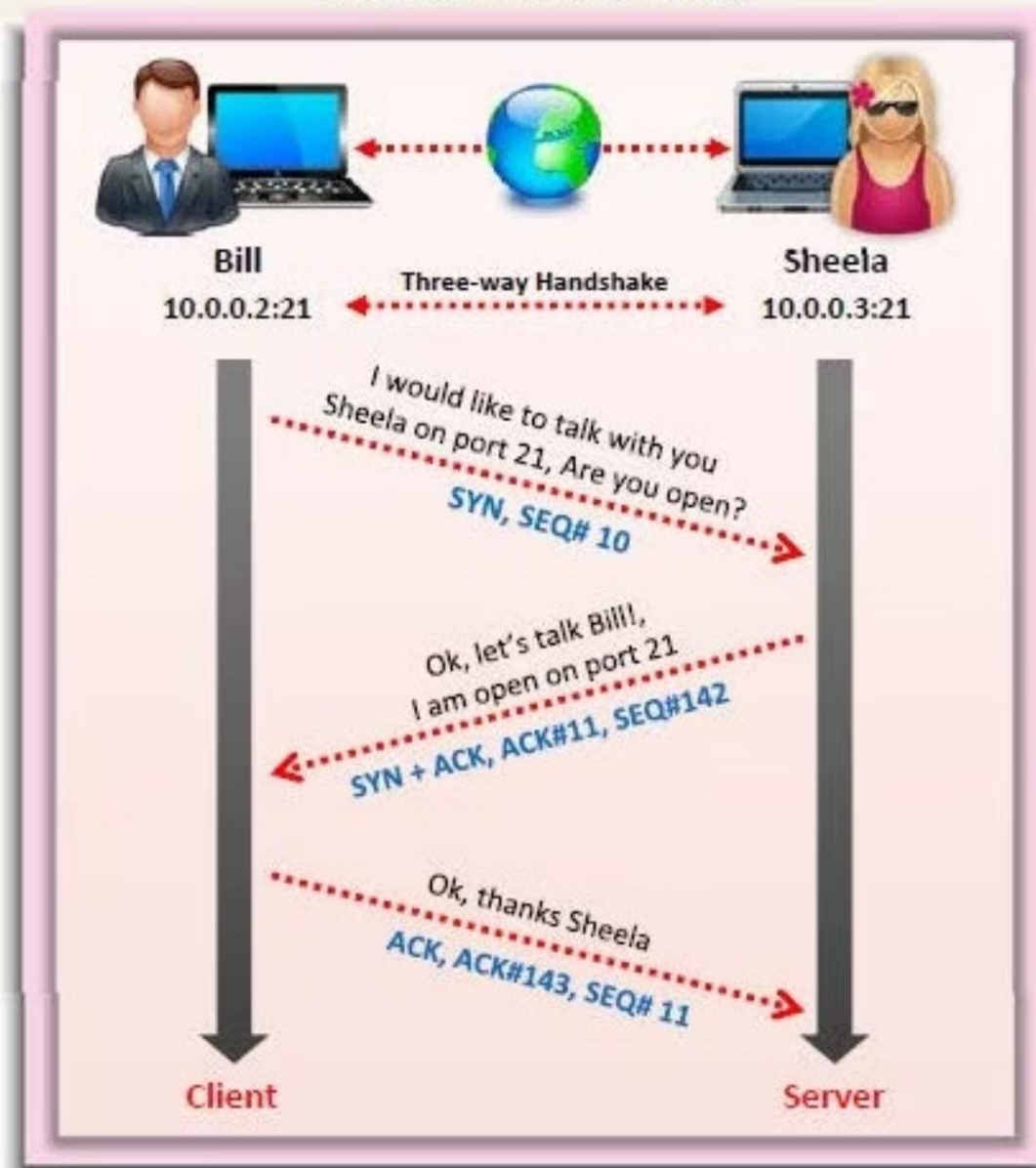
Three-Way Handshake (Session Establishment)

TCP sessions begin with a **SYN** → **SYN/ACK** → **ACK** exchange. The client sends a SYN, the server responds with SYN+ACK, and the client confirms with ACK. This synchronized exchange ensures both parties are ready to communicate.

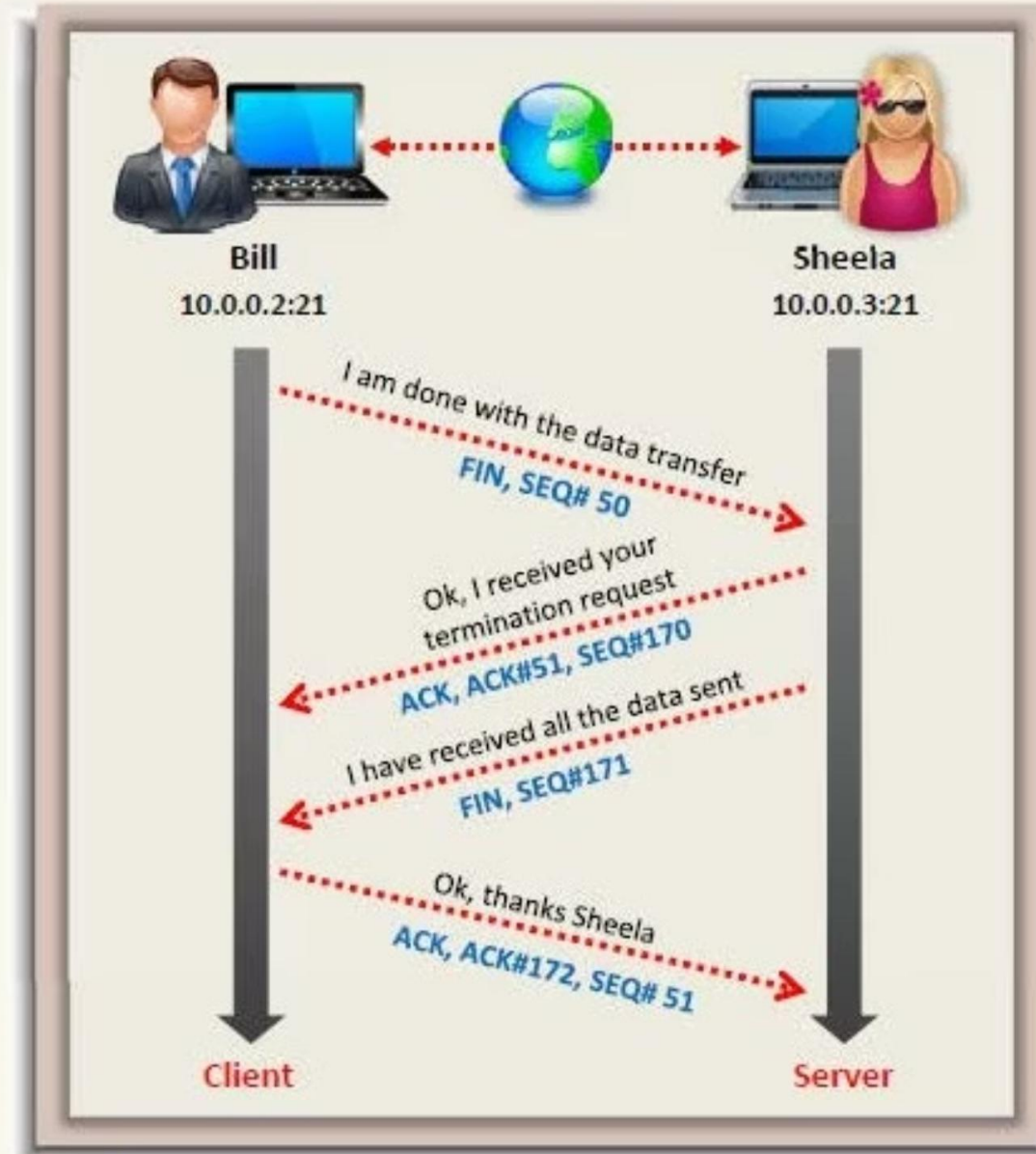
Session Termination

Sessions are gracefully terminated using **FIN** flags. The initiating side sends a FIN, the peer acknowledges it, then sends its own FIN, which is acknowledged. This four-step process ensures all data is transferred before closing.

TCP Session Establishment (Three-way Handshake)



TCP Session Termination



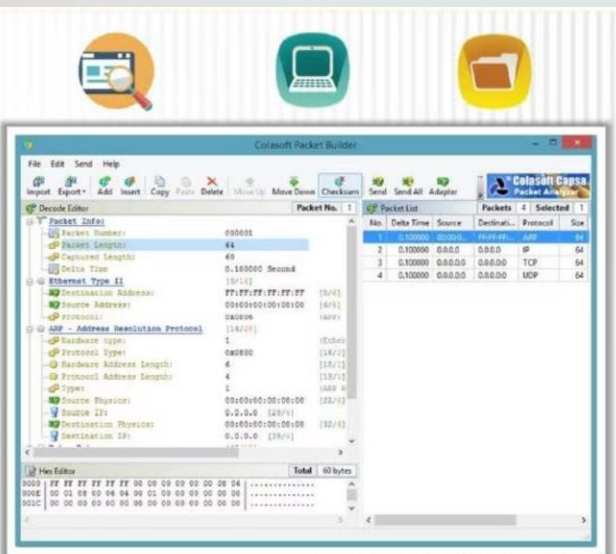
Creating Custom Packets Using TCP Flags

Legitimate Use: Network Auditing

Colasoft Packet Builder enables security professionals to create custom network packets to audit networks for various attack scenarios. Testers can craft precise packets to test firewall rules, verify IDS responses, and assess network defenses.

Malicious Use: Bypassing Defenses

Attackers can use custom packet builders to create **fragmented packets** that bypass firewalls and IDS systems. By splitting attack payloads across multiple fragments, malicious traffic can slip through security controls that inspect individual packets.



The screenshot shows the Colasoft Packet Builder application window. It features a menu bar (File, Edit, Send, Help), a toolbar, and a main workspace divided into several panes. The 'Packet Info' pane on the left lists various fields like Packet Number, Length, and Time. The 'Packet List' pane on the right shows a table of packets. The 'Hex Editor' at the bottom displays the raw packet data in hexadecimal and ASCII. Two callout boxes are present: a pink one on the top left and a brown one on the bottom left.

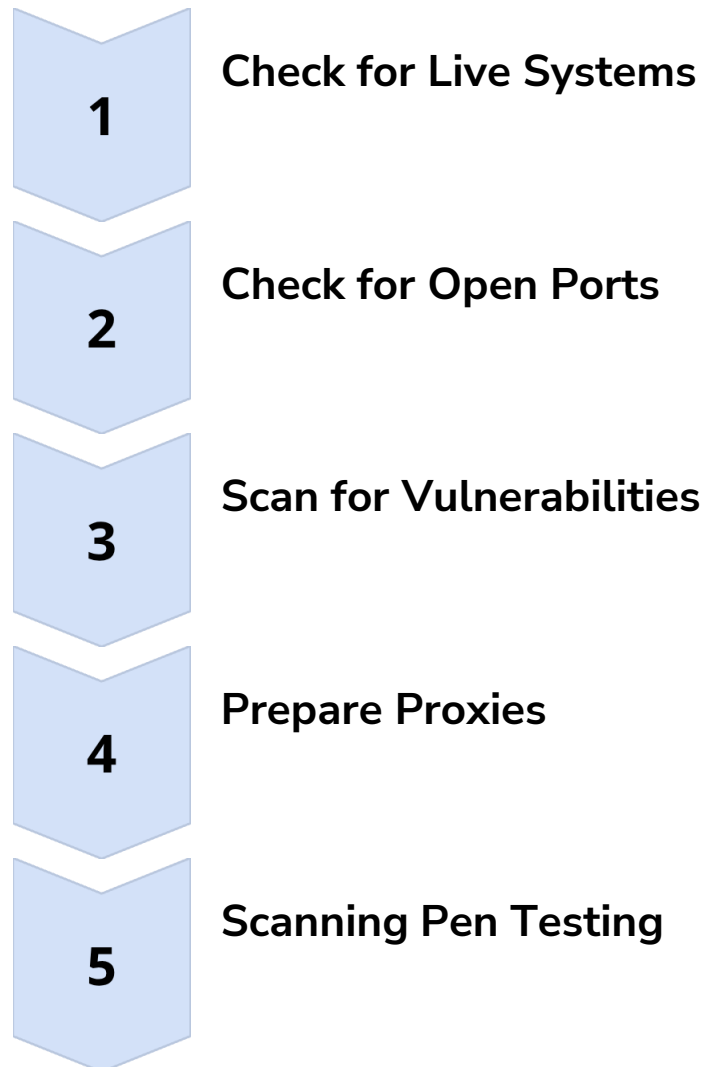
Colasoft Packet Builder enables creating custom network packets to audit networks for various attacks

Attackers can also use it to create fragmented packets to bypass firewalls and IDS systems in a network

<http://www.colasoft.com>

CEH Scanning Methodology

The CEH scanning methodology is a structured, step-by-step framework used during penetration testing to systematically enumerate a target network. Each phase builds upon the previous, moving from host discovery through vulnerability identification.

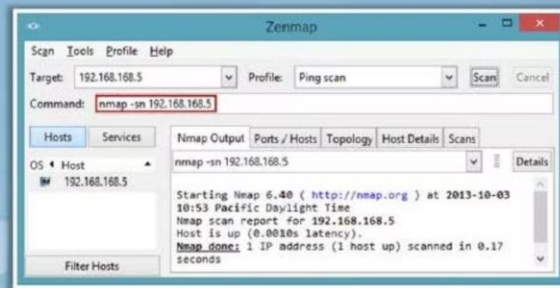


Checking for Live Systems — ICMP Scanning

- Ping scan involves sending **ICMP ECHO requests** to a host. If the host is live, it will return an ICMP ECHO reply
- This scan is useful for **locating active devices** or determining if **ICMP is passing through a firewall**



The ping scan output using Nmap:



<http://nmap.org>

How ICMP Scanning Works

A **ping scan** involves sending **ICMP ECHO requests** to a target host. If the host is live and reachable, it responds with an **ICMP ECHO reply**. This simple mechanism allows attackers and testers to confirm host availability before proceeding with deeper scans.

Practical Application

This scan is useful for **locating active devices** on a subnet and determining whether ICMP traffic is passing through a firewall. In Nmap, the ping scan is executed using the `-sn` flag (e.g., `nmap -sn 192.168.5.0/24`).

Ping Sweep

A **ping sweep** extends single-host ICMP scanning to an **entire range of IP addresses**, sending ICMP ECHO requests to multiple hosts simultaneously. Any host that is live returns an ICMP ECHO reply, allowing the attacker to build a map of active hosts.

1 Calculate Subnet Range

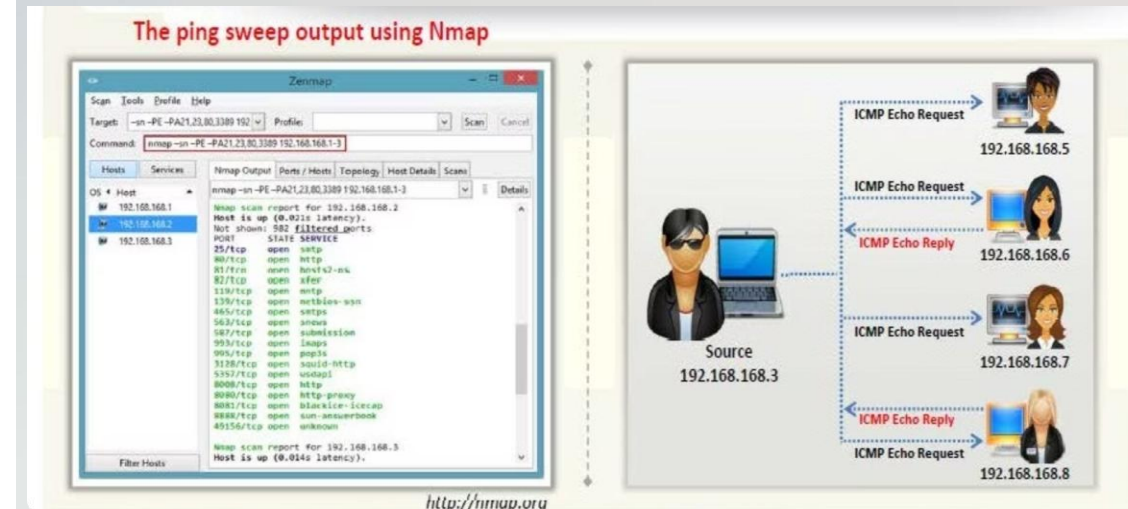
Attackers use **Subnet Mask Calculators** to identify the number of hosts present in the target subnet before initiating the sweep.

2 Execute the Sweep

ICMP requests are sent to each address in the range. Live hosts respond, revealing their presence on the network.

3 Build Live Host Inventory

The results are compiled into an **inventory of live systems** in the subnet, which guides the next phase of scanning.



Ping Sweep Tools

Angry IP Scanner

Pings each IP address to verify if it's alive, then optionally resolves its **hostname**, determines the **MAC address**, scans open ports, and retrieves NetBIOS information. Lightweight, fast, and cross-platform.

SolarWinds Engineer's Toolset

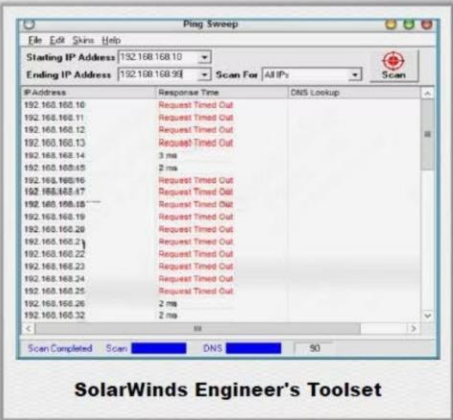
Enables scanning a range of IP addresses to identify which are in use and which are currently free. Also performs **reverse DNS lookup**, making it ideal for network administrators auditing IP address space.

Angry IP Scanner pings each IP address to check if it's alive, then optionally resolves its hostname, determines the MAC address, scans ports, etc.



<http://www.angryip.org>

SolarWinds Engineer Toolset's Ping Sweep enables scanning a range of IP addresses to identify which IP addresses are in use and which ones are currently free. It also performs **reverse DNS lookup**.



<http://www.solarwinds.com>

Additional Ping Sweep Tools

Beyond Angry IP Scanner and SolarWinds, a range of specialized tools exist to assist with host discovery via ping sweeps. These tools vary in platform support, output detail, and integration capabilities — security professionals should be familiar with multiple options.



Network Discovery

Tools that combine ping sweeps with ARP scanning for more reliable LAN-based host discovery.



Inventory Building

Many tools export results to CSV or XML, enabling integration with asset management and vulnerability tracking systems.



Cross-Platform Support

Modern sweep tools run on Windows, Linux, and macOS, and some offer mobile companion apps for on-the-go auditing.



Ping Sweep Tools: Extended Coverage

Enterprise-grade environments often require tools capable of scanning thousands of hosts across multiple subnets simultaneously. In such scenarios, [tools](#) with **scheduling capabilities**, **SNMP integration**, and **reporting dashboards** become essential.

 **Key Reminder:** Always obtain written authorization before conducting a ping sweep or any network scanning activity. Unauthorized scanning may violate computer crime laws, even in educational contexts.

CEH Scanning Methodology: Open Ports

Once live hosts are identified, the next step is **checking for open ports**. Open ports indicate running services, each of which represents a potential attack surface. The CEH methodology uses a variety of port scanning techniques to probe both TCP and UDP ports on target hosts.

Well-Known Ports (0–1023)

Reserved for system services: HTTP (80), HTTPS (443), FTP (21), SSH (22), DNS (53). Always included in a full scan.

Registered Ports (1024–49151)

Used by applications and processes. Commonly targeted for custom service enumeration.

Dynamic Ports (49152–65535)

Ephemeral ports used by client-side communications. Less commonly scanned but relevant in targeted assessments.

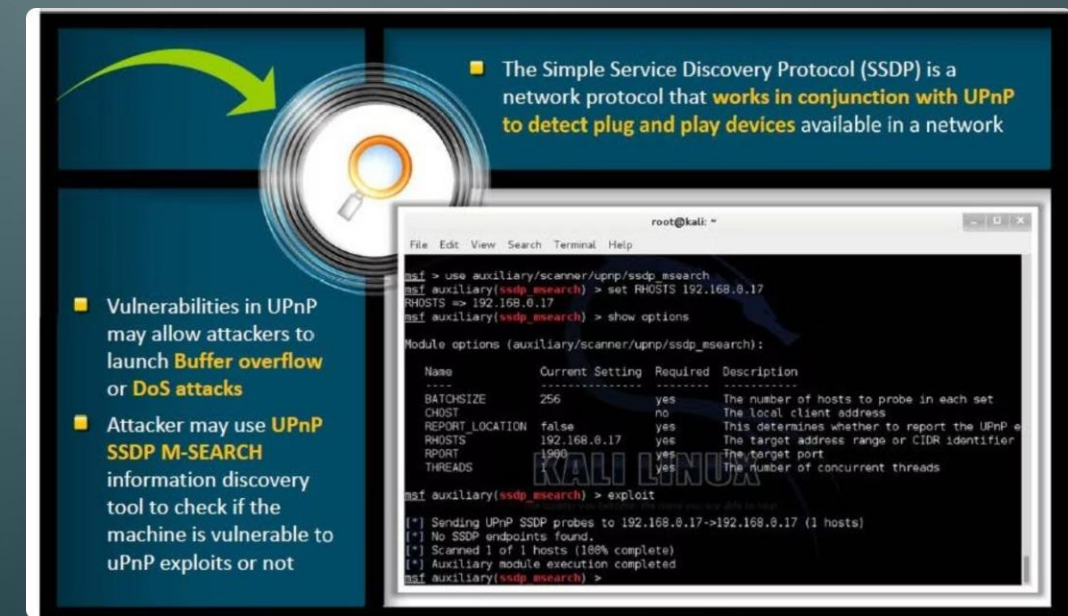
SSDP Scanning

What is SSDP?

The **Simple Service Discovery Protocol (SSDP)** is used by UPnP (Universal Plug and Play) devices to announce their presence on a local network. It operates on UDP port 1900 and relies on multicast addressing to discover services without requiring manual configuration.

Security Implications

Attackers can use SSDP to discover IoT devices, printers, routers, and media servers on a network. SSDP-based **amplification attacks** can also be leveraged for DDoS by exploiting the protocol's response behavior, making exposed SSDP services a significant security risk.



■ The Simple Service Discovery Protocol (SSDP) is a network protocol that **works in conjunction with UPnP** to detect plug and play devices available in a network

■ Vulnerabilities in UPnP may allow attackers to launch **Buffer overflow** or **DoS attacks**

■ Attacker may use **UPnP SSDP M-SEARCH** information discovery tool to check if the machine is vulnerable to uPnP exploits or not

```
root@kali: ~  
msf > use auxiliary/scanner/upnp/ssdp_msearch  
msf auxiliary(ssdp_msearch) > set RHOSTS 192.168.0.17  
RHOSTS => 192.168.0.17  
msf auxiliary(ssdp_msearch) > show options  
Module options (auxiliary/scanner/upnp/ssdp_msearch):  
-----  
Name           Current Setting  Required  Description  
-----  
BATCHSIZE      256             yes       The number of hosts to probe in each set  
CHOST           false            no        The local client address  
REPORT_LOCATION 192.168.0.17     yes       This determines whether to report the UPnP e  
RHOSTS         192.168.0.17     yes       The target address range or CIDR identifier  
REPORT         1900             yes       The target port  
THREADS        yes              yes       The number of concurrent threads  
msf auxiliary(ssdp_msearch) > exploit  
[*] Sending UPnP SSDP probes to 192.168.0.17->192.168.0.17 (1 hosts)  
[*] No SSDP endpoints found.  
[*] Scanned 1 of 1 hosts (100% complete)  
[*] Auxiliary module execution completed  
msf auxiliary(ssdp_msearch) >
```

Scanning in IPv6 Networks

IPv6's massive address space — **2^{128} possible addresses** — makes traditional brute-force scanning impractical. An attacker cannot simply iterate through a /64 subnet the way they might in IPv4. This fundamentally changes the scanning methodology for IPv6 environments.

Multicast Scanning

IPv6 uses multicast instead of broadcast. Sending packets to multicast groups (e.g., ff02::1) can reveal all hosts on a local segment.

Neighbor Discovery Protocol

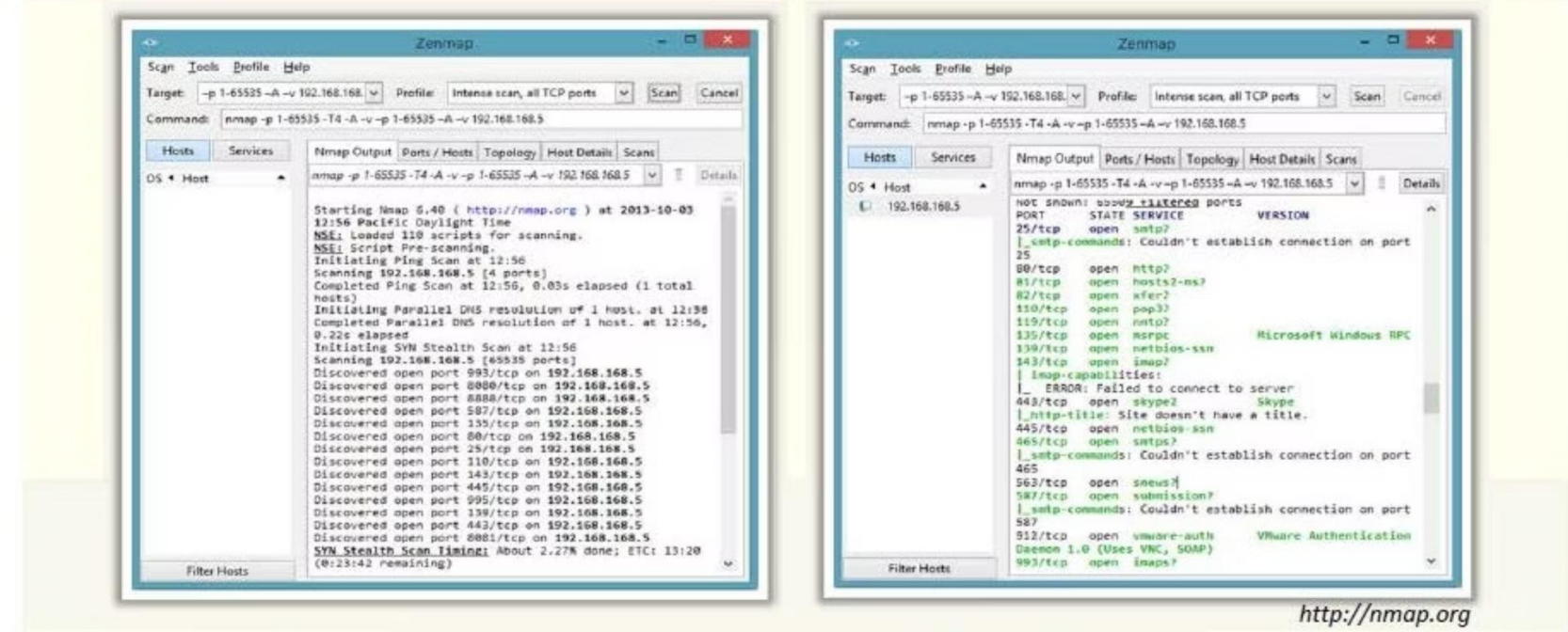
NDP (replacing ARP) can be queried to enumerate link-local hosts. Tools like Nmap support IPv6 scanning with the `-6` flag.

DNS & Log Mining

Attackers pivot to DNS zone transfers, router advertisements, and log files to discover valid IPv6 addresses without brute-forcing.

Scanning Tool: Nmap

- 01 Network administrators can use Nmap for network inventory, managing service upgrade schedules, and monitoring host or service uptime
- 02 Attacker uses Nmap to extract information such as live hosts on the network, services (application name and version), type of packet filters/firewalls, operating systems and OS versions



Nmap (Network Mapper) is the industry-standard open-source tool for network discovery and security auditing. It uses raw IP packets to determine available hosts, open ports, running services, OS versions, and many other characteristics.

- sS (SYN Stealth Scan)**
Fast, stealthy TCP scan that does not complete the handshake.
- sV (Version Detection)**
Probes open ports to determine service/version information.
- O (OS Detection)**
Uses TCP/IP stack fingerprinting to identify operating systems.
- A (Aggressive Scan)**
Enables OS detection, version detection, script scanning, and traceroute simultaneously.
- p (Port Range)**
Specifies which ports to scan. Use `-p-` to scan all 65535 ports.
- script (NSE Scripts)**
Runs Nmap Scripting Engine scripts for advanced vulnerability detection.

Hping2 / Hping3

Hping2/Hping3 is a powerful command-line TCP/IP packet assembler and analyzer. Unlike standard ping tools, Hping allows users to craft and transmit custom packets at the TCP, UDP, ICMP, and raw IP levels — making it invaluable for both security testing and network troubleshooting.

Key Capabilities

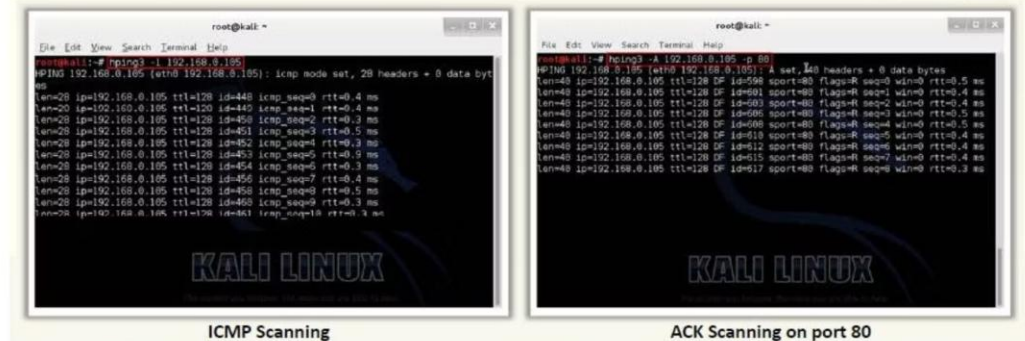
- Firewall testing and rule auditing
- Advanced port scanning beyond standard Nmap
- Network performance measurement and MTU discovery
- TCP/IP stack auditing with custom flags
- Traceroute with any protocol

Why It Matters for CEH

Hping3 gives ethical hackers **granular control** over packet construction. By manually setting TCP flags, sequence numbers, and payloads, testers can simulate specific attack scenarios and probe defenses in ways that automated scanners cannot replicate.

- 1 Command line **network scanning** and **packet crafting** tool for the TCP/IP protocol
- 2 It can be used for **network security auditing**, **firewall testing**, manual path MTU discovery, advanced traceroute, remote OS fingerprinting, remote uptime guessing, TCP/IP stacks auditing, etc.

<http://www.hping.org>



```
root@kali:~# hping3 -I 192.168.0.105
PING 192.168.0.105 (eth0 192.168.0.105): icmp node set, 28 headers + 0 data bytes
len=20 ip=192.168.0.105 ttl=128 id=448 icmp_seq=0 rtt=0.4 ms
len=20 ip=192.168.0.105 ttl=128 id=449 icmp_seq=1 rtt=0.4 ms
len=20 ip=192.168.0.105 ttl=128 id=450 icmp_seq=2 rtt=0.2 ms
len=20 ip=192.168.0.105 ttl=128 id=451 icmp_seq=3 rtt=0.5 ms
len=20 ip=192.168.0.105 ttl=128 id=452 icmp_seq=4 rtt=0.3 ms
len=20 ip=192.168.0.105 ttl=128 id=453 icmp_seq=5 rtt=0.0 ms
len=20 ip=192.168.0.105 ttl=128 id=454 icmp_seq=6 rtt=0.3 ms
len=20 ip=192.168.0.105 ttl=128 id=455 icmp_seq=7 rtt=0.4 ms
len=20 ip=192.168.0.105 ttl=128 id=456 icmp_seq=8 rtt=0.5 ms
len=20 ip=192.168.0.105 ttl=128 id=457 icmp_seq=9 rtt=0.3 ms
len=20 ip=192.168.0.105 ttl=128 id=458 icmp_seq=10 rtt=0.3 ms

root@kali:~# hping3 -A 192.168.0.105 -p 80
ping 192.168.0.105 (eth0 192.168.0.105): A set, 28 headers + 0 data bytes
len=40 ip=192.168.0.105 ttl=128 DF id=598 sport=80 flags=R seq=0 win=0 rtt=0.5 ms
len=40 ip=192.168.0.105 ttl=128 DF id=599 sport=80 flags=R seq=1 win=0 rtt=0.4 ms
len=40 ip=192.168.0.105 ttl=128 DF id=600 sport=80 flags=R seq=2 win=0 rtt=0.4 ms
len=40 ip=192.168.0.105 ttl=128 DF id=601 sport=80 flags=R seq=3 win=0 rtt=0.5 ms
len=40 ip=192.168.0.105 ttl=128 DF id=602 sport=80 flags=R seq=4 win=0 rtt=0.5 ms
len=40 ip=192.168.0.105 ttl=128 DF id=603 sport=80 flags=R seq=5 win=0 rtt=0.4 ms
len=40 ip=192.168.0.105 ttl=128 DF id=604 sport=80 flags=R seq=6 win=0 rtt=0.4 ms
len=40 ip=192.168.0.105 ttl=128 DF id=605 sport=80 flags=R seq=7 win=0 rtt=0.4 ms
len=40 ip=192.168.0.105 ttl=128 DF id=606 sport=80 flags=R seq=8 win=0 rtt=0.3 ms
```

ICMP Scanning

ACK Scanning on port 80

Hping Commands

Hping3 commands follow the syntax: `hping3 [options] target`. Below are essential commands used in ethical hacking engagements:

SYN Flood Test

```
hping3 -S --flood -V -p 80 target
```

Sends a high volume of SYN packets to test DoS resistance.

ICMP Ping

```
hping3 -1 target
```

Sends ICMP echo requests, similar to a standard ping.

UDP Scan

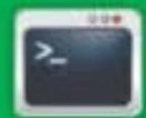
```
hping3 -2 -p 161 target
```

Sends UDP packets to a specific port to probe for active services.

ACK Scan

```
hping3 -A -p 80 target
```

Sends ACK packets to determine firewall stateful filtering rules.



ICMP Ping

```
hping3 -1 10.0.0.25
```



SYN scan on port 50-60

```
hping3 -8 50-60 -S 10.0.0.25 -V
```



ACK scan on port 80

```
hping3 -A 10.0.0.25 -p 80
```



FIN, PUSH and URG scan on port 80

```
hping3 -F -P -U 10.0.0.25 -p 80
```



UDP scan on port 80

```
hping3 -2 10.0.0.25 -p 80
```



Scan entire subnet for live host

```
hping3 -1 10.0.1.x --rand-dest  
-I eth0
```



Collecting Initial Sequence Number

```
hping3 192.168.1.103 -Q -p 139 -s
```



Intercept all traffic containing HTTP signature

```
hping3 -9 HTTP -I eth0
```



Firewalls and Time Stamps

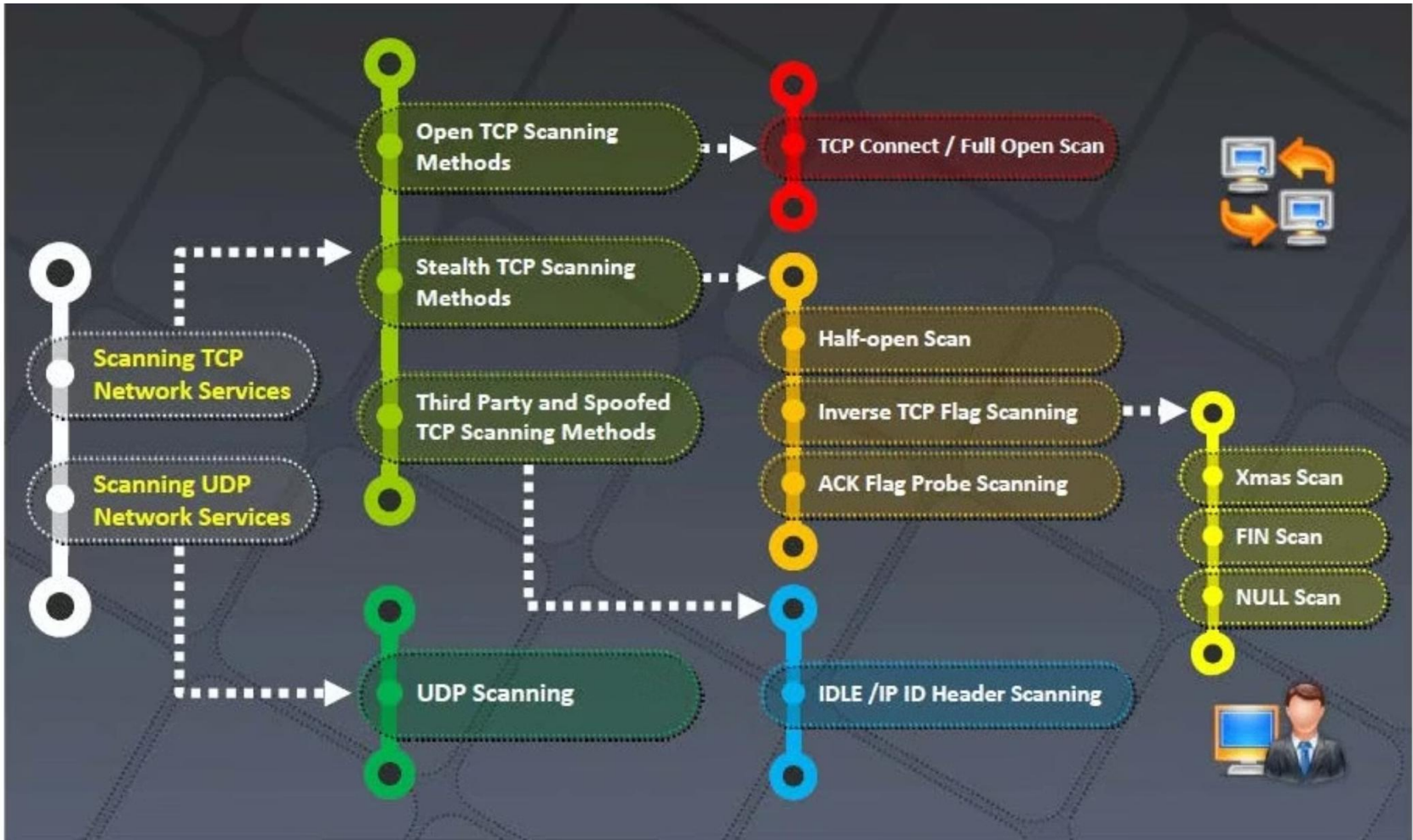
```
hping3 -S 72.14.207.99 -p 80 --  
tcp-timestamp
```



SYN flooding a victim

```
hping3 -S 192.168.1.1 -a  
192.168.1.254 -p 22 --flood
```

Scanning Techniques Overview



Network scanning employs a variety of techniques, each leveraging different TCP/IP behaviors to determine port states. The choice of technique depends on the level of stealth required, the type of firewall or IDS in place, and the target operating system.

01	02	03
TCP Connect / Full Open Scan Completes the full three-way handshake. Reliable but easily logged.	Stealth / SYN Scan Sends SYN, receives SYN/ACK, then sends RST — never completing the handshake.	Inverse TCP & Xmas Scans Use unusual flag combinations to evade detection by older IDS systems.
04	05	
ACK Flag Probe Determines firewall rules by sending ACK packets and analyzing RST responses.	IDLE / IPID Scan Uses a zombie host to conduct completely anonymous port scanning.	

TCP Connect / Full Open Scan

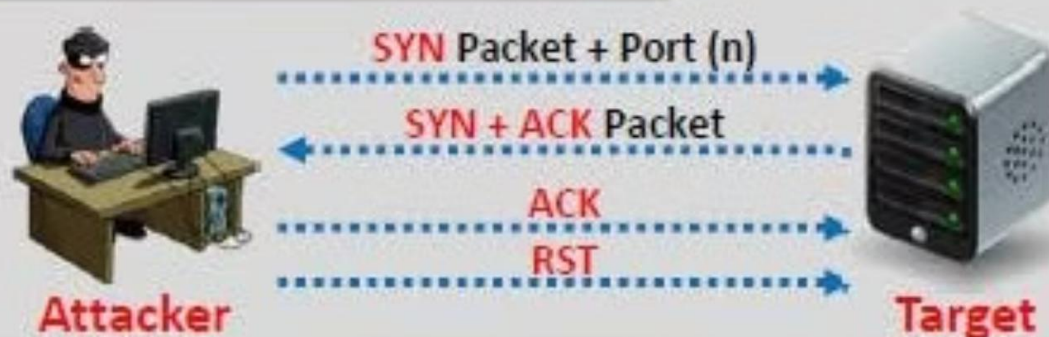
How It Works

The TCP Connect scan completes the **full three-way handshake** (SYN → SYN/ACK → ACK) with each target port. If the port is open, the handshake succeeds. **If closed, the target responds with RST.** This is the most reliable scan type.

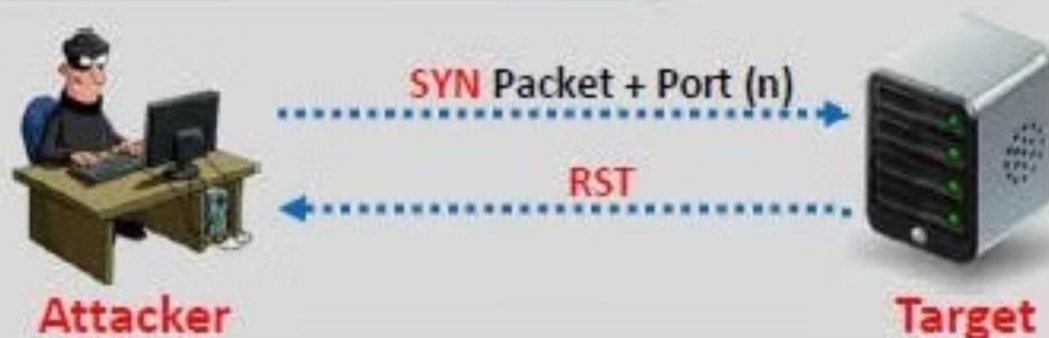
Advantages & Disadvantages

- **Advantage:**
 - Does not require raw socket privileges — works without admin/root access
 - Highly accurate port state determination
- **Disadvantage:**
 - Easily detected and logged by firewalls and IDS systems
 - Leaves a clear audit trail on target systems

Scan result when a port is open



Scan result when a port is closed



Target: nmap 192.168.0.97

Command: # -sT -v nmap 192.168.0.97

Hosts: Services: Nmap Output: Ports / Hosts: Topology: Host Details: Scans: Details

```

Starting Nmap 6.40 ( http://nmap.org ) at 2014-02-24 10:33
Initiating ARP Ping Scan at 10:33
Scanning 192.168.0.97 [1 port]
Completed ARP Ping Scan at 10:33, 0.04s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 10:33
Completed Parallel DNS resolution of 1 host. at 10:33, 0.03s elapsed
Initiating Connect Scan at 10:33
Scanning 192.168.0.97 [1000 ports]
Discovered open port 25/tcp on 192.168.0.97
Discovered open port 110/tcp on 192.168.0.97
Discovered open port 135/tcp on 192.168.0.97
Discovered open port 143/tcp on 192.168.0.97
Discovered open port 445/tcp on 192.168.0.97
Discovered open port 25/tcp on 192.168.0.97
Discovered open port 993/tcp on 192.168.0.97
Discovered open port 995/tcp on 192.168.0.97
Discovered open port 465/tcp on 192.168.0.97
Connect Scan Timing: About 47.93% done; ETC: 10:34 (0:00:34 remaining)
Discovered open port 119/tcp on 192.168.0.97
Discovered open port 563/tcp on 192.168.0.97
Completed Connect Scan at 10:34, 62.34s elapsed (1000 total ports)
Nmap scan report for 192.168.0.97
Failed to resolve "nmap".
Host is up (0.00030s latency).
Not shown: 900 filtered ports
PORT      STATE SERVICE
25/tcp    open  smtp
110/tcp   open  pop3
135/tcp   open  msrpc
143/tcp   open  imap
445/tcp   open  microsoft-ds
465/tcp   open  smtps
563/tcp   open  pop3s
993/tcp   open  imap3
995/tcp   open  pop3s
MAC Address: 08:00:27:00:00:00 (Dell)
  
```

Stealth Scan (Half-Open Scan)

The **SYN scan** (or half-open scan) is the most popular scanning technique in ethical hacking. It sends a SYN packet and waits for a response — if a SYN/ACK is received, the port is open. The scanner then sends an **RST** to abort the connection before it is fully established, avoiding logging on many systems.

- Stealth scan involves resetting the TCP connection between client and server abruptly before completion of **three-way handshake signals** making the connection half open
- Attackers use stealth scanning techniques to **bypass firewall rules, logging mechanism**, and hide themselves as usual network traffic

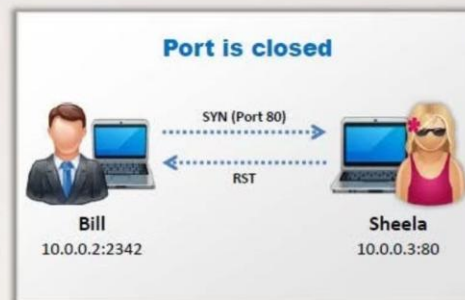
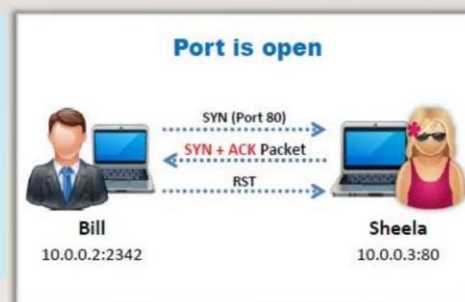
Stealth Scan Process

01 The client sends a single **SYN** packet to the server on the appropriate port

02 If the port is open then the server responds with a **SYN/ACK** packet

03 If the server responds with an **RST** packet, then the remote port is in the "closed" state

04 The client sends the **RST** packet to close the initiation before a connection can ever be established



Port Open

Target responds with **SYN/ACK**.
Scanner sends RST to close. Port confirmed open.

Port Closed

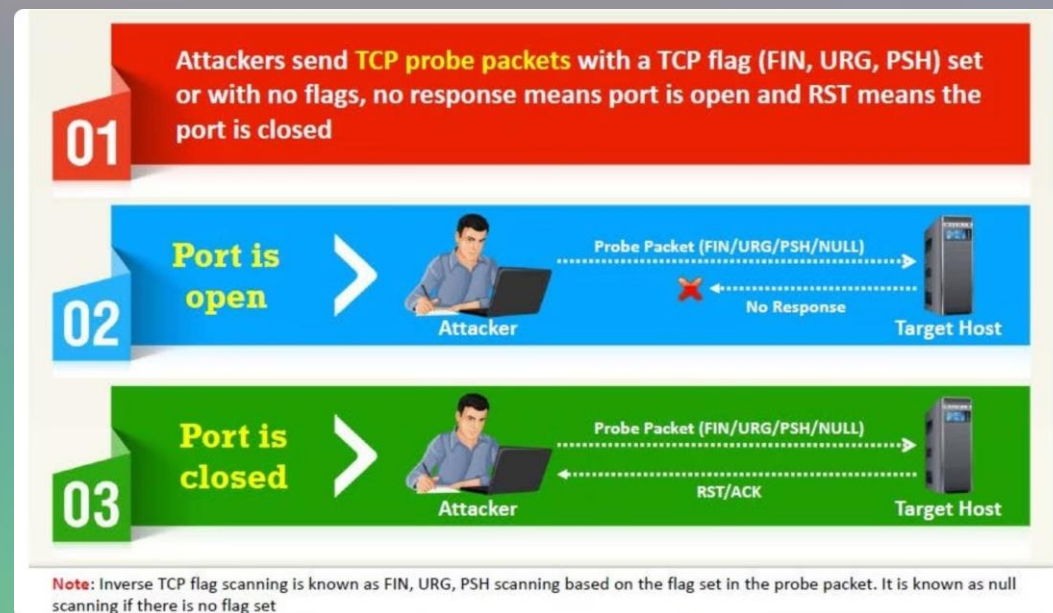
Target responds with **RST** immediately. Port confirmed closed.

Port Filtered

No response received. Firewall is likely dropping packets silently.

Inverse TCP Flag Scanning

Inverse TCP flag scanning exploits the behavior defined in **RFC 793**: closed ports must respond to non-SYN packets with an RST, while open ports simply drop the packet with no response. These techniques are effective against some IDS systems that only monitor SYN packets.



NULL Scan (-sN)

Sends a TCP packet with **no flags set**. No response = open or filtered. RST = closed port.

FIN Scan (-sF)

Sends a TCP packet with only the **FIN flag** set. Bypasses some firewalls that block SYN packets.

XMAS Scan

Sets **FIN, URG, and PSH** flags simultaneously — the packet "lights up like a Christmas tree."

Xmas Scan

How the Xmas Scan Works

The **Xmas scan** sets the **FIN**, **URG**, and **PSH** flags simultaneously. Like other inverse scans, it relies on RFC 793 behavior: **closed ports return an RST**, while **open ports do not respond**. The unusual flag combination can confuse older or misconfigured security devices.

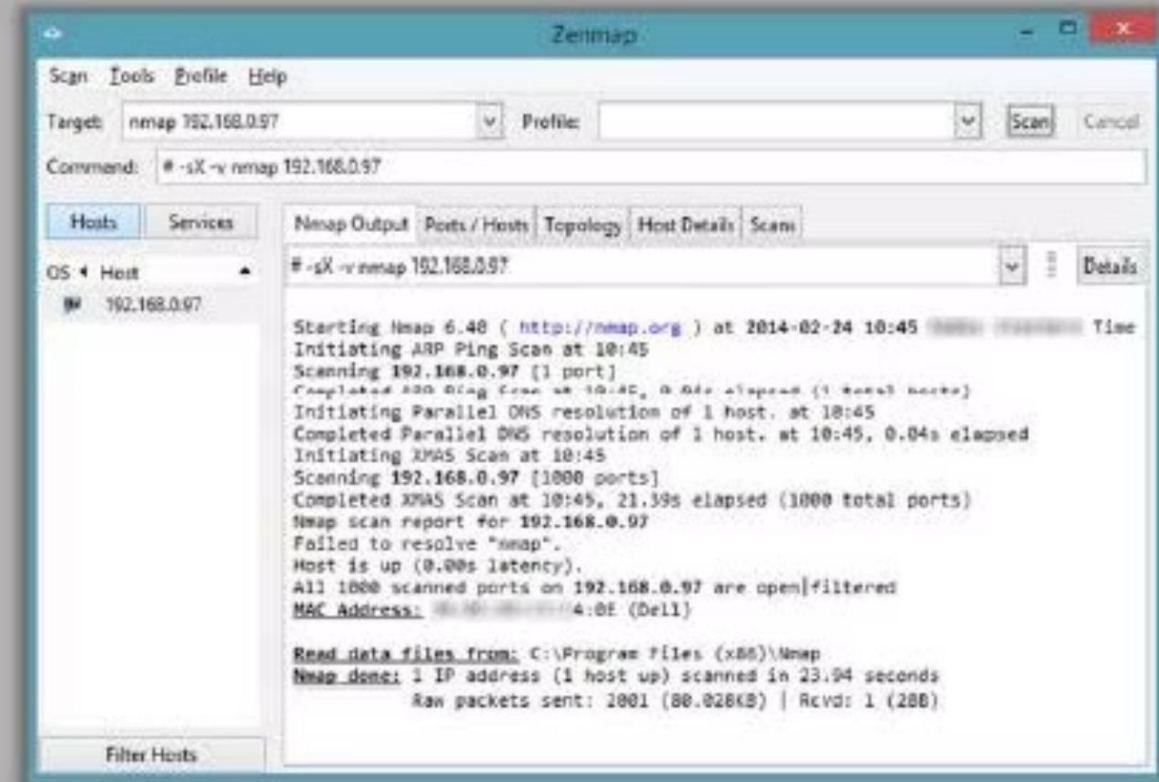
Limitations

- Does not work reliably against **Windows systems**, which respond with RST regardless of port state
- Modern IDS systems detect the abnormal flag combination
- Cannot distinguish between **open** and **filtered** ports when no response is received
- Results may be unreliable in complex network environments

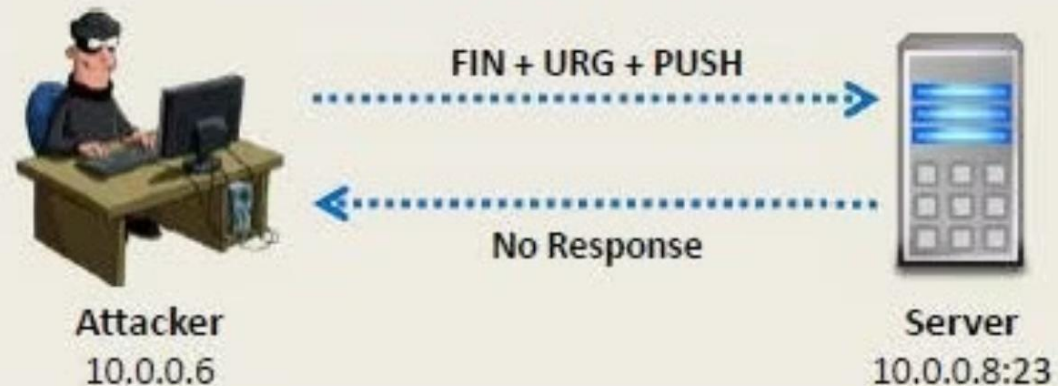
In Xmas scan, attackers send a TCP frame to a remote device with **FIN**, **URG**, and **PUSH** flags set

FIN scan works only with OSES with **RFC 793-based** TCP/IP implementation

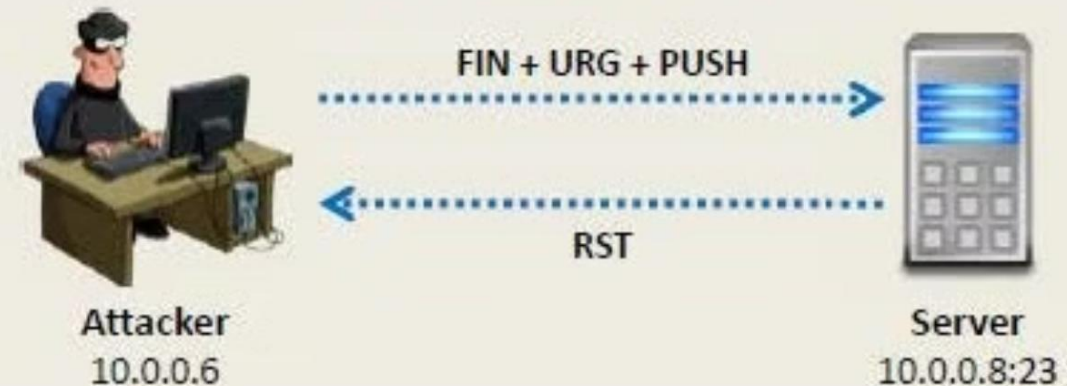
It will not work against any current version of **Microsoft Windows**



Port is open

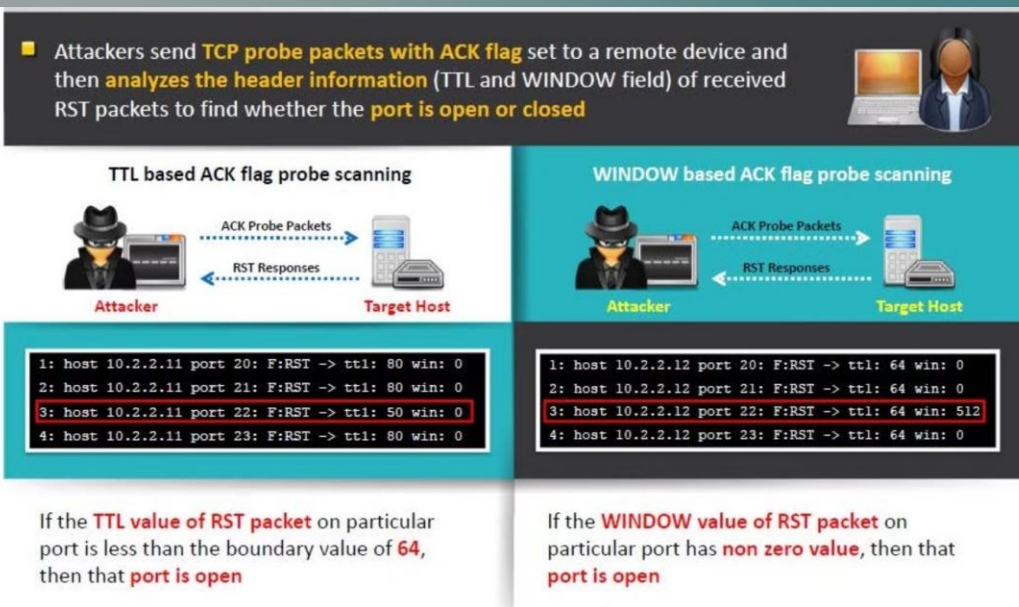


Port is closed



ACK Flag Probe Scanning

The **ACK flag probe scan** sends TCP packets with the ACK flag set to probe a target. Unlike SYN scans that determine open ports, ACK scanning is primarily used to **map firewall rules** and determine whether a firewall is stateful or stateless.



RST Response Received

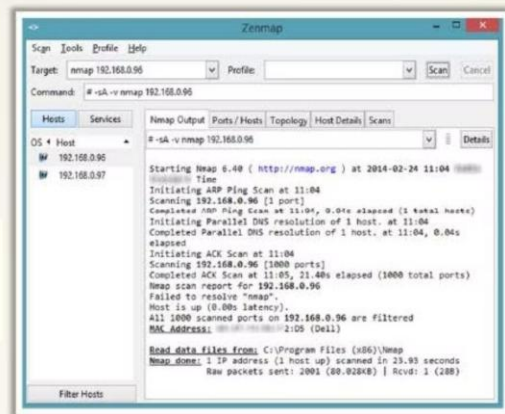
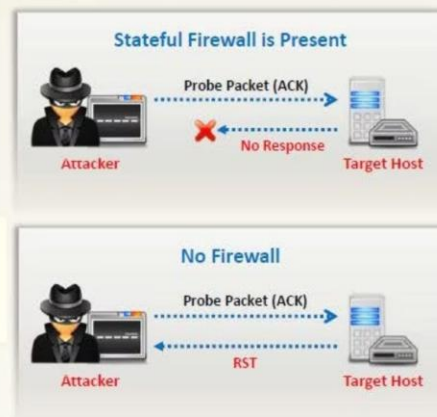
The port is **unfiltered** — the packet reached the host. Does not indicate whether the port is open or closed.

No Response / ICMP Error

The port is **filtered** — a firewall or packet filter is blocking the ACK packet from reaching the host.

ACK Flag Probe Scanning (Cont'd)

- ACK flag probe scanning can also be used to **check the filtering system of target**
- Attackers send an **ACK probe packet** with random sequence number, no response means **port is filtered** (stateful firewall is present) and RST response means the **port is not filtered**



TTL-Based Analysis

In TTL-based ACK scanning, the **Time To Live (TTL)** value of RST responses is analyzed. RST packets with a TTL less than 64 may indicate an **open port**, while those with $TTL \geq 64$ suggest the port is closed. This method reveals information even when basic firewall rules are in place.

Window-Based Analysis

In window-based scanning, the **TCP window size** in RST responses is examined. A non-zero window value in the RST response may indicate an open port. This technique can differentiate open and closed ports on certain operating systems without triggering standard IDS alerts.

IDLE / IPID Header Scan

01

Most network servers listen on TCP ports, such as **web servers on port 80** and **mail servers on port 25**. Port is considered “open” if an application is listening on the port

02

One way to determine whether a port is open is to **send a "SYN"** (session establishment) packet to the port

03

The target machine will send back a **"SYN|ACK"** (session request acknowledgment) packet if the port is open, and an **"RST" (Reset) packet** if the port is closed

04

A machine that receives an **unsolicited SYN|ACK packet** will respond with an RST. An unsolicited RST will be ignored

05

Every IP packet on the Internet has a **"fragment identification" number** (IPID)

06

OS increments the IPID for each packet sent, thus probing an IPID gives an attacker the **number of packets sent** since last probe

Command Prompt

C:\>nmap -Pn -p- -sI www.juggyboy.com www.certifiedhacker.com
Starting Nmap (http://nmap.org)
Idlescan using zombie www.juggyboy.com (192.130.18.124:80); Class: Incremental
Nmap scan report for 198.182.30.110
(The 40321 ports scanned but not shown below are in state: closed)
Port State Service
21/tcp open ftp
25/tcp open smtp
80/tcp open http
Nmap done: 1 IP address (1 host up) scanned in 1931.23 seconds

The **IDLE scan** is one of the most sophisticated and stealthy scanning techniques available. It allows an attacker to scan a target **completely anonymously** by using a passive third-party host — called a **zombie** — as an intermediary, so the scan appears to originate from the zombie.

1

Probe the Zombie

The attacker probes the zombie host to determine its current **IP ID (IPID)** value — a counter incremented for each packet the zombie sends.

2

Forge a SYN Packet

The attacker sends a **spoofed SYN packet** to the target, making it appear to come from the zombie's IP address.

3

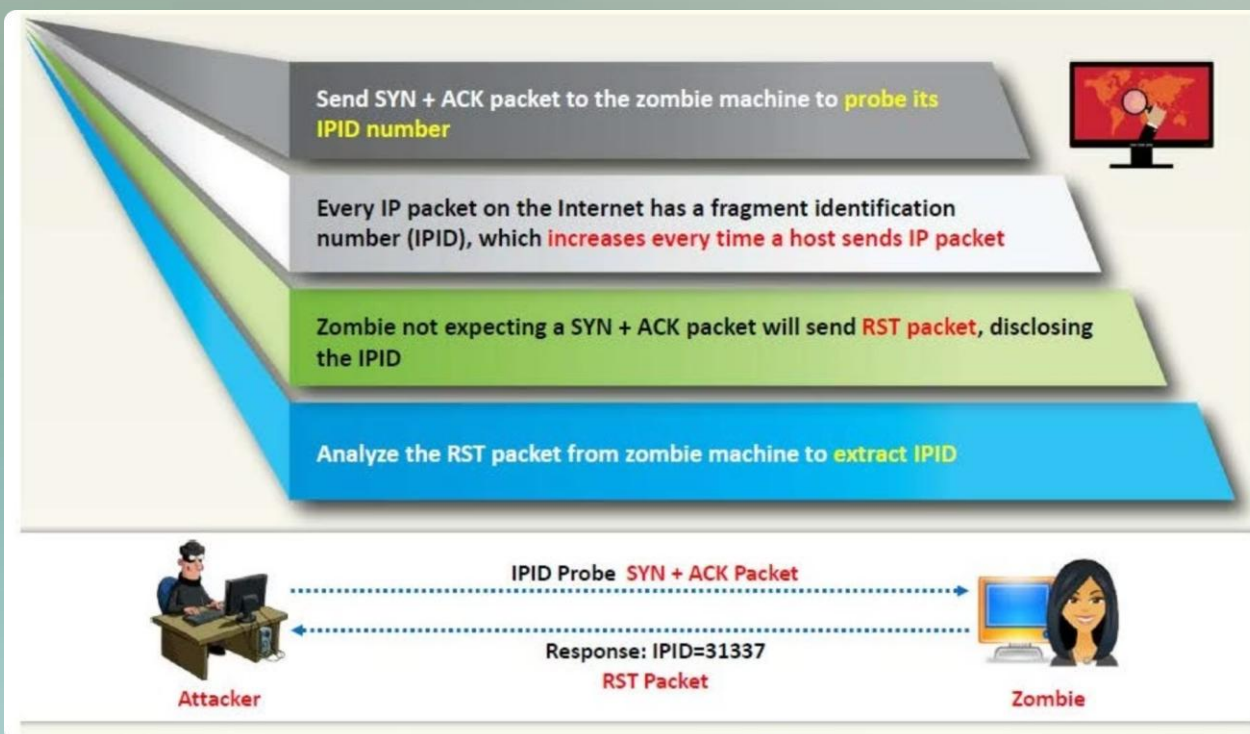
Analyze IPID Change

By probing the zombie again and measuring the **IPID increment**, the attacker can determine whether the target port is open or closed.

IDLE Scan: Step 1

Step 1: Probe the Zombie Host's IPID. The attacker sends a SYN/ACK packet to the zombie host. Since no connection was established, the zombie responds with an RST packet. The **IPID value in that RST response** is recorded — this is the baseline for comparison after the spoofed probe is sent to the target.

 **Key Concept:** The zombie must be a host with predictable, sequential IPID values and low network activity. An active host generating its own traffic would produce unreliable IPID increments, making the technique ineffective.



IDLE Scan: Steps 2 and 3

Step 2: Spoof SYN to Target

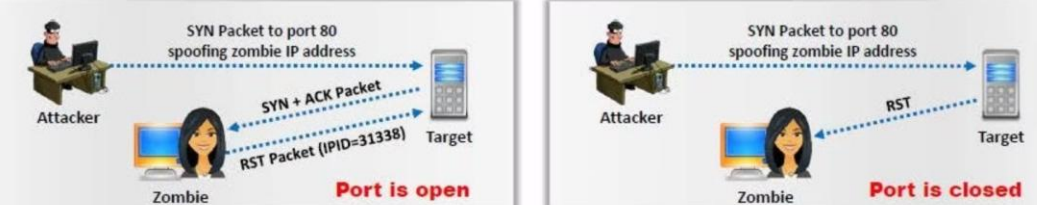
- The attacker sends a **SYN packet to the target**, with the **source IP spoofed** to match the zombie's IP address.
- If the target port is **open**, it replies with SYN/ACK to the zombie — causing the zombie to send an RST, incrementing its IPID by 1.

Step 3: Re-Probe and Compare

- The attacker probes the zombie a second time to read its new IPID.
- If IPID increased by **2**, the target port is **open**. If it increased by only **1**, the port is **closed**.
- This clever technique reveals target port state with **zero direct contact** from the attacker's IP.

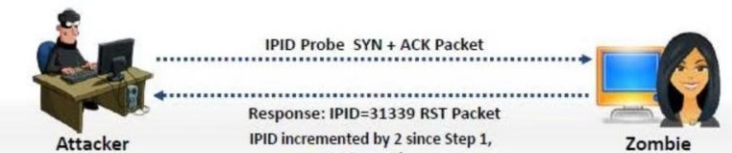
Step 2

- Send SYN packet to the **target machine (port 80)** spoofing the IP address of the “zombie”
- If the port is open, the target will send **SYN+ACK Packet** to the zombie and in response zombie sends RST to the target
- If the port is closed, the target will send **RST to the “zombie”** but zombie will not send anything back



Step 3

- Probe “zombie” IPID again



UDP Scanning

UDP scanning targets **connectionless UDP services** such as DNS (53), SNMP (161), DHCP (67/68), and TFTP (69). Unlike TCP, UDP has no handshake — making port state detection more ambiguous and inherently slower.

Open UDP Port

Target responds with a **UDP packet**.

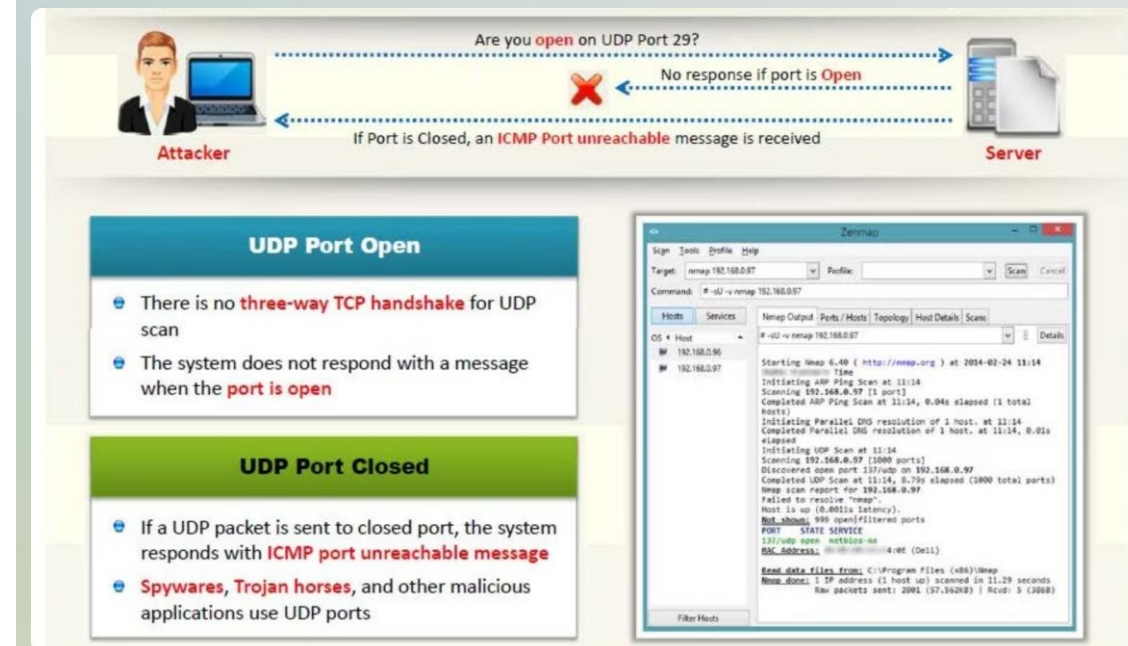
No ICMP unreachable message is returned. Port is confirmed open.

Closed UDP Port

Target returns an **ICMP Port Unreachable (Type 3, Code 3)** message. Port is confirmed closed.

Filtered / Open

No response received. The port may be open (dropping packets) or filtered by a firewall — cannot distinguish without further probing.



ICMP Echo Scanning / List Scan

ICMP Echo Scanning

Beyond basic ping, ICMP scanning includes **ICMP Timestamp Requests (Type 13)** and **Address Mask Requests (Type 17)**, which can reveal host uptime and subnet information. These are useful when echo requests are blocked by firewalls but other ICMP types are permitted.

List Scan (-sL)

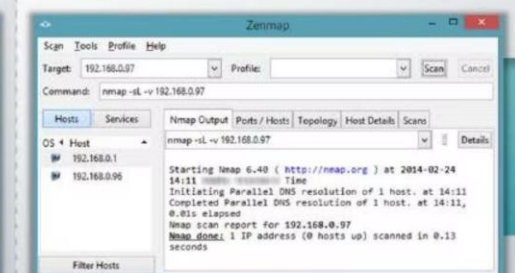
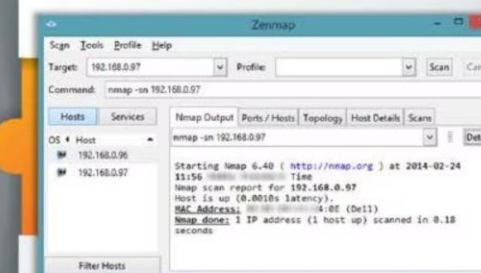
The Nmap **list scan** does not send any packets to the target hosts. Instead, it **performs a reverse DNS lookup** for each IP in the target range to resolve hostnames. This is an extremely low-impact reconnaissance technique — ideal for initial enumeration without alerting IDS systems.

ICMP Echo Scanning

- This is not really port scanning, since **ICMP** does not have a port abstraction
- But it is sometimes useful to determine which hosts in a network are up by **pinging** them all
- `nmap -P cert.org/24 152.148.0.0/16`

List Scan

- This type of scan simply generates and prints a **list of IPs/Names** without actually pinging them
- A **reverse DNS resolution** is carried out to identify the host names



Scanning Tool: NetScan Tools Pro

NetScan Tools Pro is a comprehensive Windows-based network security toolkit used by network engineers and security professionals. It consolidates over 40 network utilities into a single interface, supporting a broad range of scanning and discovery tasks.



Port & Service Scanning

Scan TCP/UDP ports, identify running services, and enumerate open connections across a target network.



DNS Tools

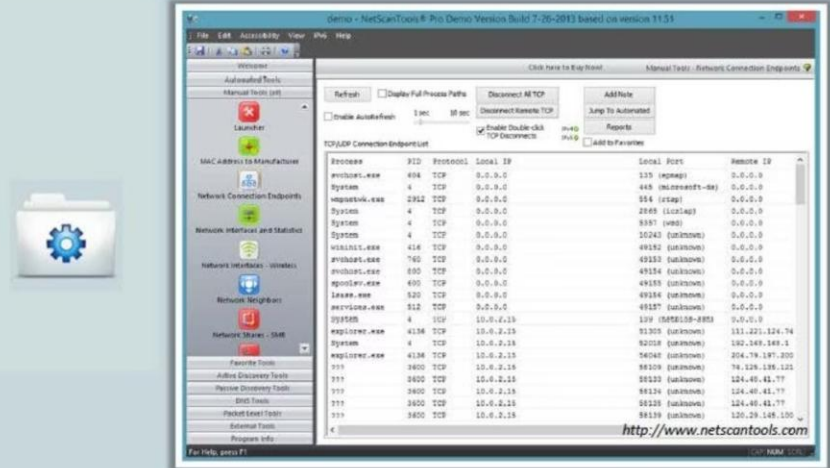
Perform forward/reverse lookups, zone transfers, and WHOIS queries with built-in DNS diagnostic utilities.



Network Discovery

Ping sweeps, ARP scanning, and traceroute functionality to map the active topology of a target network.

- Network Tools Pro assists in **troubleshooting**, **diagnosing**, **monitoring** and **discovering** devices on the network
- It lists **IPv4/IPv6** addresses, hostnames, **domain names**, email addresses, and URLs automatically or with manual tools



Scanning Tools

 SuperScan http://www.mcafee.com	 Network Inventory Explorer http://www.10-strike.com
 PRTG Network Monitor http://www.paessler.com	 Global Network Inventory Scanner http://www.magnetosoft.com
 Net Tools http://mabsoft.com	 SoftPerfect Network Scanner http://www.softperfect.com
 IP-Tools http://www.ks-soft.net	 Advanced Port Scanner http://www.radmin.com
 MegaPing http://www.magnetosoft.com	 CurrPorts http://www.nirsoft.net

The security toolkit ecosystem offers a rich variety of scanning tools, each suited to specific tasks. Familiarity with multiple tools is essential for a professional ethical hacker, as different environments and engagement scopes demand different capabilities.

Nmap The gold standard for port scanning, OS fingerprinting, and service detection. Cross-platform and scriptable via NSE.	Masscan Transmits up to 10 million packets per second — ideal for scanning the entire internet or large address blocks rapidly.	Unicornscan Asynchronous TCP/UDP scanner built for high-speed, distributed scanning with custom packet crafting.	Zenmap The official Nmap GUI front-end, making it easier to run complex scans and visualize network topology maps.
ScanLine A fast, lightweight Windows command-line port scanner supporting TCP/UDP scanning and banner grabbing.		NetScan Tools Pro Comprehensive Windows toolkit combining over 40 utilities for network scanning and diagnostics.	

Scanning Tools for Mobile

Mobile devices running Android and iOS are increasingly used in security auditing, particularly for physical penetration testing and on-site network assessments. Several powerful tools bring desktop-grade scanning capability to smartphones and tablets.

Network Scanner (iOS)

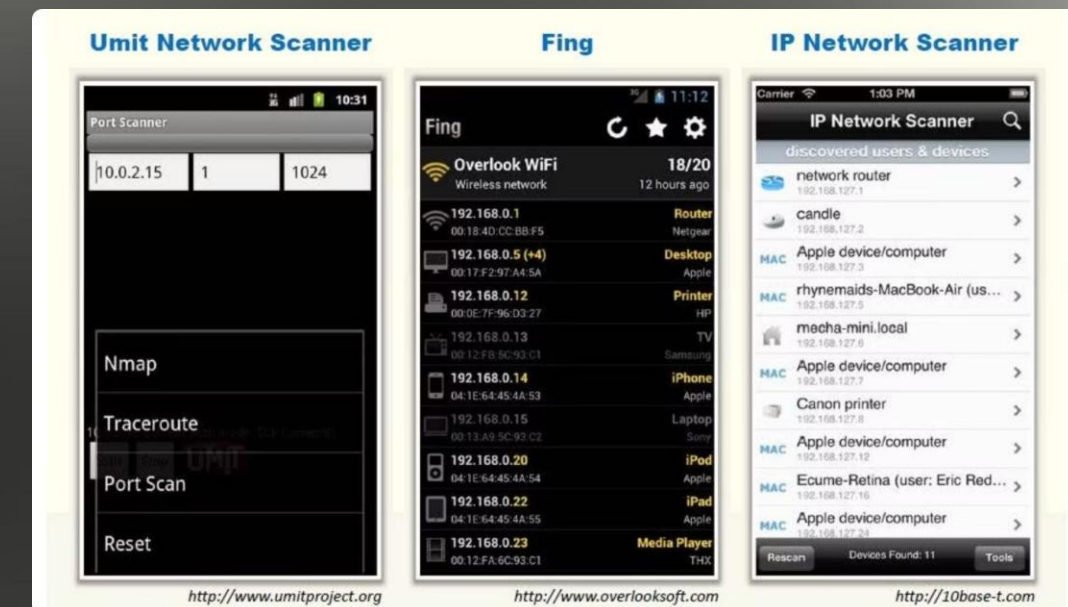
Discovers all active devices on a Wi-Fi network. Shows IP address, device name, MAC address, and open ports.

Fing (Android/iOS)

Professional-grade network scanner that identifies devices, vendors, open ports, and services. Widely used for rapid network audits.

zAnti (Android)

A comprehensive mobile penetration testing toolkit including network scanning, MITM attacks, and password auditing — requires root access.



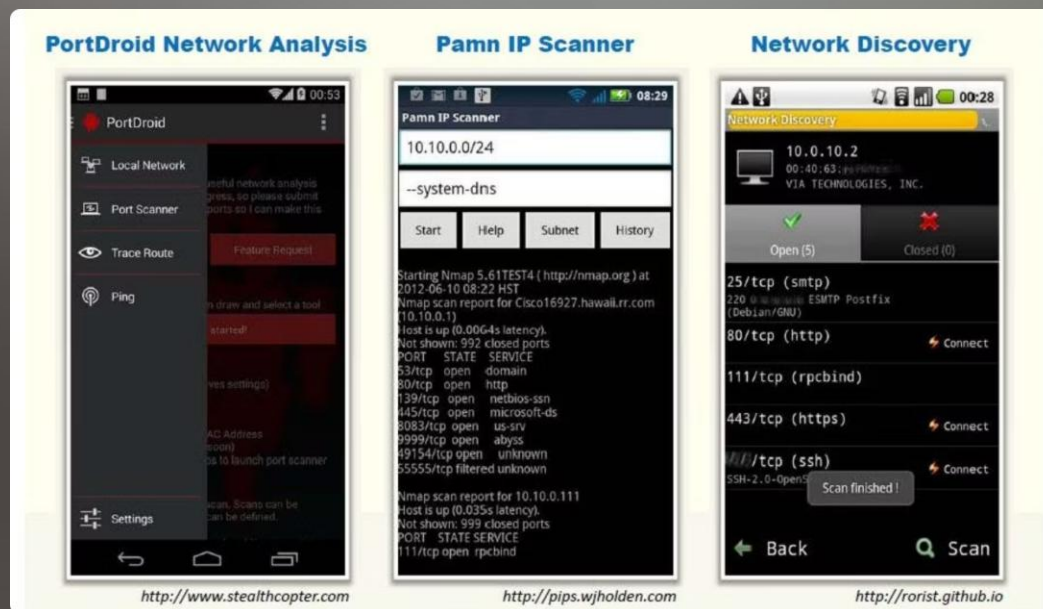
Scanning Tools for Mobile (Cont'd)

IP Scanner Pro (Android)

Fast and feature-rich LAN scanner that identifies connected devices, shows open ports, and resolves device names. Supports custom port scanning ranges and export of results for offline analysis.

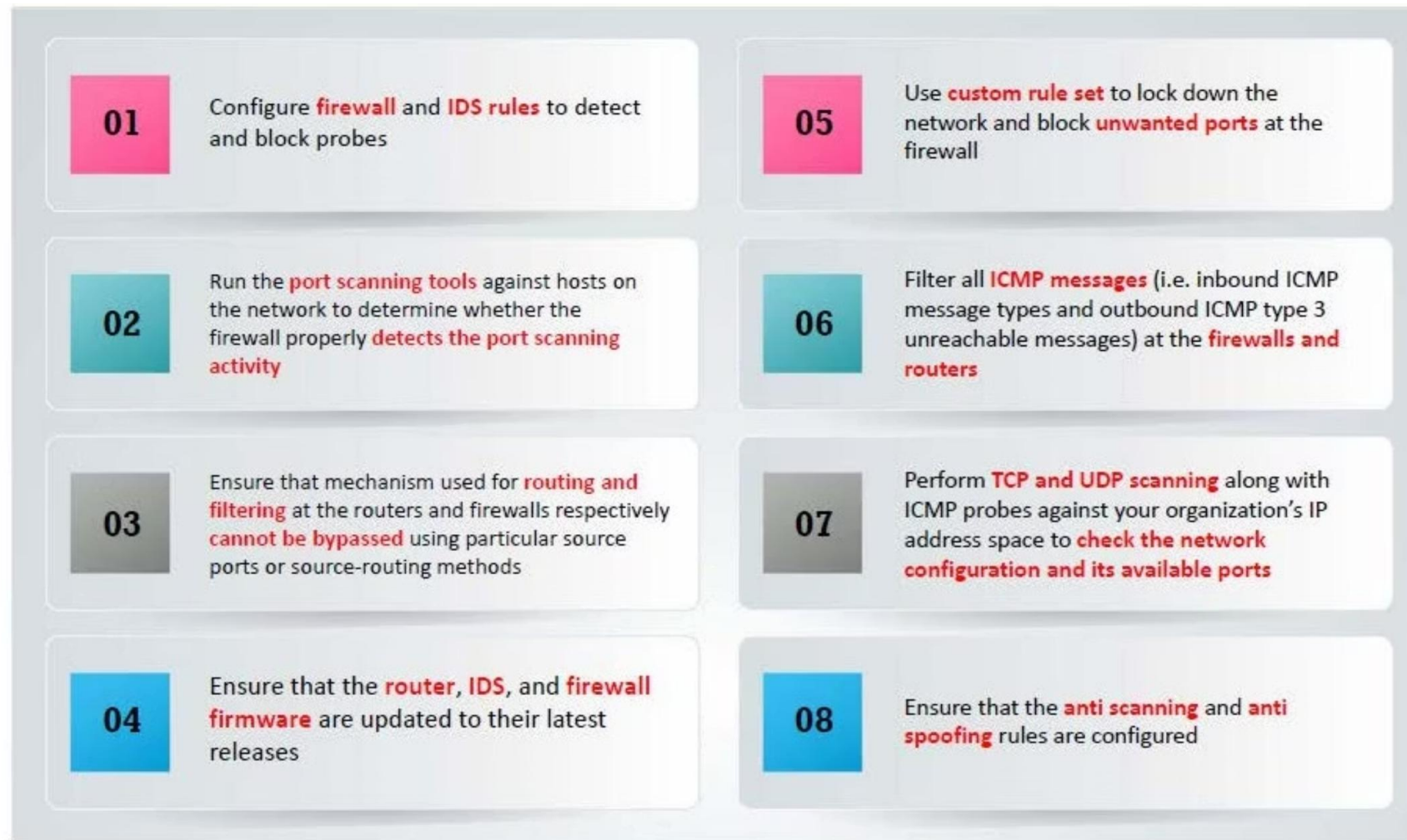
Nmap for Android

The full Nmap engine compiled for Android devices. Requires rooted device for advanced scan types (SYN scans, OS detection). Provides the same capabilities as desktop Nmap in a mobile form factor, making it extremely powerful for on-site assessments.



📄 **Note:** Mobile scanning tools must only be used on networks you own or have explicit written authorization to test. Unauthorized scanning of wireless networks may violate the Computer Fraud and Abuse Act (CFAA) and similar laws.

Port Scanning Countermeasures



Defenders must deploy layered countermeasures to detect and mitigate port scanning activity. Understanding scanning techniques from an attacker's perspective enables security teams to build more effective defenses.

→ Configure Firewalls & IDS/IPS

Deploy stateful firewalls and intrusion detection systems configured to **detect abnormal port probe patterns** — including SYN floods, NULL scans, and XMAS scans.

→ Use Network Segmentation

Segment the network into security zones. Even if an attacker discovers open ports in one segment, **lateral movement** to sensitive systems is restricted.

→ Implement Port Filtering

Block unnecessary ports and protocols at the perimeter. Apply the **principle of least privilege** to network services — only expose what is absolutely required.

→ Monitor & Alert on Scan Patterns

Deploy SIEM solutions to correlate port scan events across multiple sources and **alert security teams** to reconnaissance activity in real time.

CEH Scanning Methodology: Scanning Beyond IDS

Modern networks are protected by **Intrusion Detection Systems (IDS)** that monitor for scanning signatures. Ethical hackers must understand IDS evasion techniques not only to conduct thorough assessments but also to help organizations strengthen their detection capabilities.

Packet Fragmentation

Splitting attack packets into small fragments to prevent IDS reassembly and inspection.

Decoy Scanning

Using Nmap's `-D` option to send scans from multiple decoy IP addresses simultaneously, obscuring the real source.

Slow Scanning

Introducing long delays between probes to fall below IDS rate-based detection thresholds.

Source Port Manipulation

Setting scan source ports to trusted values (e.g., 80, 443) that firewalls and IDS often permit by default.

IDS Evasion Techniques

Attackers use a range of sophisticated IDS evasion techniques to conduct scanning and exploitation activities without triggering alerts. Security professionals must be familiar with these methods to configure effective detection rules.

1

IP Spoofing

Sending packets with a **forged source IP address** to disguise the origin of the scan. Often combined with decoy scanning.

2

Proxy Chains

Routing scan traffic through a **chain of proxy servers** or anonymizing networks (e.g., Tor) to obscure the attacker's true IP.

3

Encryption & Tunneling

Encapsulating scan traffic within **encrypted tunnels** (SSH, SSL) or protocol tunnels that IDS cannot inspect.

4

TTL Manipulation

Setting **short TTL values** so that modified/malicious packets expire before reaching the IDS sensor but after reaching the target.

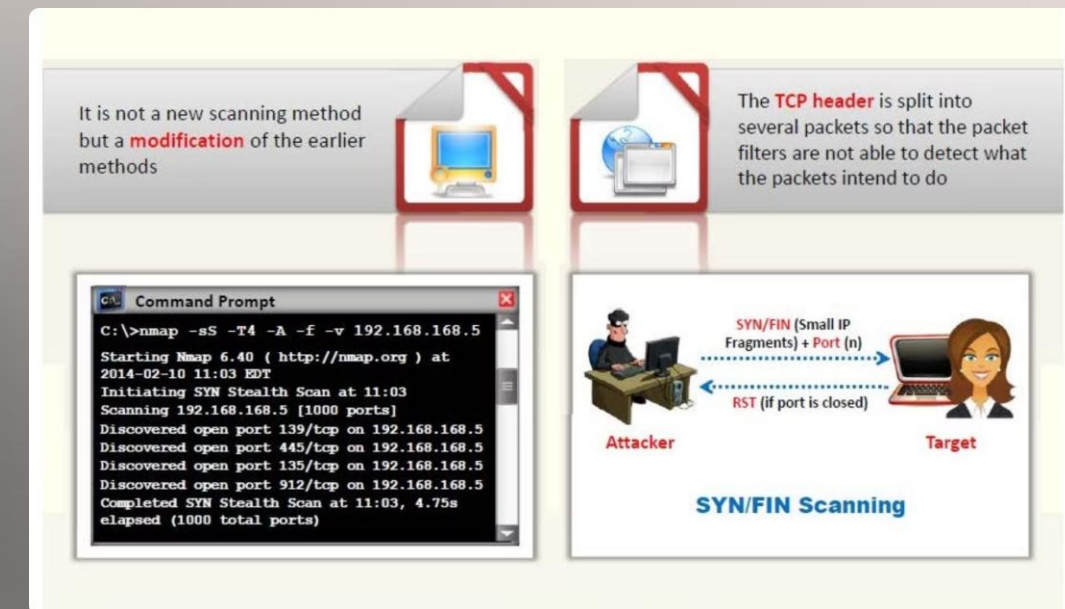
SYN/FIN Scanning Using IP Fragments

How IP Fragmentation Evades IDS

By splitting TCP headers across **multiple small IP fragments**, attackers prevent IDS systems from inspecting the full packet header. The IDS sees only fragments — not the complete SYN or FIN packet — and may fail to match its attack signatures, allowing the scan to proceed undetected.

Nmap Implementation

Nmap supports fragmented scanning using the `-f` flag, which divides packets into 8-byte fragments. The `--mtu` option allows custom fragment sizes. Combining fragmentation with other evasion techniques (decoys, slow timing) significantly reduces detection probability against signature-based IDS sensors.



Module 3 Summary: Network Scanning

Network Scanning Fundamentals

Scanning is a critical intelligence gathering phase. Objectives include discovering live hosts, open ports, running services, and vulnerabilities.

TCP/IP Foundations

Understanding TCP flags (SYN, ACK, FIN, RST, URG, PSH) and the three-way handshake is essential for crafting and interpreting scan packets.

Scanning Techniques

From full TCP connect scans to stealthy SYN, IDLE, and inverse TCP flag techniques — each has distinct advantages and detection profiles.

Tools & Countermeasures

Nmap, Hping3, and NetScan Tools Pro are key tools. Countermeasures include IDS/IPS deployment, packet filtering, segmentation, and monitoring.

End of Lecture 3

Thank you for attending **ICT306 Advanced Cybersecurity — Lecture 3: Network Scanning**. Review the prescribed reading (Meredith, 2022, Module 03) before the next session. Practice the techniques covered using authorized lab environments only.

Next Steps

Complete Module 03 reading and attempt the practice questions in the CEH v12 Exam Guide.

Lab Work

Practice Nmap and Hping3 commands in the authorized virtual lab environment provided on the course portal.

Next Lecture

Lecture 4 will cover Enumeration — building on the scanning methodology to extract detailed system and service information.